Guide de Réalisation : Born2beRoot (42 School)

Objectif : Ce document sert de feuille de route technique pour le projet Born2beRoot. Il détaille les étapes critiques, les pièges à éviter et les concepts techniques sous-jacents (mémoire, processus, système de fichiers) pour garantir la conformité avec le sujet et la norme 42.

> ⚠️ **RÈGLE D'OR : Ne jamais copier-coller du code sans le comprendre. Chaque commande doit être maîtrisée. Ce guide est un support de réflexion, pas une solution à exécuter aveuglément.**

1. Livrables et Soumission (Git)

Votre dépôt Git ne doit contenir **QUE** deux fichiers à la racine :

1. `README.md` : Documentation du projet.
2. `signature.txt` : Contient l'empreinte SHA1 de votre disque virtuel.

> **INTERDIT :** Pousser la machine virtuelle (.vdi), les scripts, ou tout autre fichier sur le Git. Cela entraînera un 0 immédiat.

Le fichier signature.txt

Concept : L'empreinte SHA1 est une somme de contrôle cryptographique unique générée à partir du contenu binaire de votre fichier de disque virtuel. Elle prouve que la machine évaluée est exactement celle que vous avez soumise.

Comment la générer :

- Éteignez complètement votre machine virtuelle.
- Localisez le fichier de disque (extension `.vdi` pour VirtualBox, `.qcow2` pour UTM).
- Exécutez la commande appropriée selon votre OS hôte :

    - **Linux :** `sha1sum nom_de_votre_vm.vdi`
    - **MacOS :** `shasum nom_de_votre_vm.vdi`
    - **Windows :** `certUtil -hashfile nom_de_votre_vm.vdi sha1`
- Copiez la chaîne hexadécimale résultante (ex: `6e657c4619944be17df3c31faa030c25e43e40af`) dans le fichier `signature.txt`.

Attention : La signature change dès que la machine démarre ou que le disque est modifié. Pour les évaluations, il est conseillé de faire un snapshot propre avant la soutenance, ou de dupliquer le fichier .vdi pour figer sa signature.

2. Gestion des Snapshots (VirtualBox)

Concept technique : Un snapshot fige l'état actuel du disque virtuel. Toute modification ultérieure est écrite dans un fichier différentiel. Le disque original reste intact.

- **Utilité :** Permet de tester des configurations risquées (ex: modification de `sudoers` ou du firewall) et de revenir instantanément à un état stable en cas d'erreur critique.
- **Règle de soutenance :** Le sujet interdit la présence de snapshots **au début** de l'évaluation. Vous devez supprimer tous les snapshots avant de lancer la VM pour la correction.
- **Stratégie recommandée :**
    1. Créez un snapshot "BASE_SAINE" après l'installation de base.
    2. Créez des snapshots intermédiaires avant chaque grosse modification.
    3. Avant la soutenance : Supprimez tous les snapshots (en fusionnant les changements dans le disque principal) ou créez un nouveau snapshot propre "EVAL" et supprimez les anciens.

3. Installation et Partitionnement (Étape Critique)

C'est l'étape la plus difficile à modifier après coup. Une erreur ici impose souvent une réinstallation complète.

Prérequis Installation

- **OS :** Debian Stable (Dernière version). **Aucune interface graphique** (pas de GNOME, KDE, X.org, Wayland).
- **Hostname :** Doit être défini durant l'install : `sperrin42`.
- **Utilisateur :** Créer l'utilisateur `sperrin42`.

Schéma de Partitionnement (LVM + Chiffrement)

Le sujet exige au moins 2 partitions chiffrées utilisant LVM. Voici l'architecture standard recommandée :

1. **Partition 1 (/boot) :**
    - Taille : ~1 Go.
    - Type : Primaire, ext4.
    - **NON chiffrée** (le bootloader doit pouvoir la lire sans mot de passe).
    - Point de montage : `/boot`.
2. **Partition 2 (LVM Crypté) :**
    - Taille : Le reste du disque.
    - Utiliser comme : Volume physique pour chiffrement (LUKS).
    - Créer un Groupe de Volumes (VG) dans ce volume chiffré.
    - Dans ce VG, créer deux Volumes Logiques (LV) :
        - **LV 1 (Racine) :** Format ext4, point de montage `/`.
        - **LV 2 (Swap) :** Type "swap" (mémoire d'échange).

Mécanisme : Au démarrage, le noyau charge l'initramfs, demande la clé de déchiffrement LUKS, déverrouille le groupe de volumes, puis monte la racine. Si vous ratez cette étape, le système ne démarrera pas.

4. Configuration Post-Installation

A. Mise à jour et Outils

Après le premier boot, mettez à jour les paquets et installez les outils nécessaires :

- `sudo`, `ufw` (firewall), `cron`, `lvm2`, `openssh-server`, `net-tools` (pour ifconfig), `service`.

B. Configuration SSH (Port 4242 & Sécurité)

Fichier : `/etc/ssh/sshd_config`

- Changer le port : `Port 4242`
- Interdire root : `PermitRootLogin no`
- Redémarrer le service : `sudo systemctl restart ssh`
- **Vérification :** Tenter de se connecter en root (doit échouer) et sur le port 22 (doit échouer).

C. Firewall (UFW)

Le sujet impose UFW pour Debian.

- Activer UFW : `sudo ufw enable`
- Autoriser UNIQUEMENT le port 4242 : `sudo ufw allow 4242/tcp`
- Vérifier le statut : `sudo ufw status verbose` (Doit afficher "Active" et seulement 4242/tcp en ALLOW).

D. Politique de Mots de Passe (PAM)

Configuration via `/etc/login.defs` et `/etc/pam.d/common-password`.

Exigence	Fichier / Paramètre	Valeur
Expiration	`/etc/login.defs` (PASS_MAX_DAYS)	30
Min jours entre changements	`/etc/login.defs` (PASS_MIN_DAYS)	2
Avertissement avant expiration	`/etc/login.defs` (PASS_WARN_AGE)	7
Longueur min	`/etc/pam.d/common-password` (pam_pwquality)	minlen=10
Complexité (maj, min, chiffre)	`/etc/pam.d/common-password`	ucredit, lcredit, dcredit

Pas de nom d'utilisateur	`/etc/pam.d/common-password`	reject_username
Pas >3 chars identiques	`/etc/pam.d/common-password`	dcredit / configuration spécifique

Action requise : Une fois configuré, changez immédiatement les mots de passe de `root` et `sperrin42` pour qu'ils respectent les nouvelles règles. Le mot de passe root doit aussi respecter la politique (sauf la règle des 7 chars différents de l'ancien, qui ne s'applique qu'aux utilisateurs normaux).

E. Configuration Sudo (Sécurité & Logs)

Fichier : `/etc/sudoers` (À éditer UNIQUEMENT avec `sudo visudo`).

- **Essais max :** `Defaults passwd_tries=3`
- **Message d'erreur :** `Defaults badpass_message="Message personnalisé"`
- **TTY requis :** `Defaults requiretty`
- **Chemin sécurisé :** `Defaults secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin"`
- **Logging :**
  - Créer le dossier : `sudo mkdir /var/log/sudo`
  - Ajouter dans sudoers : `Defaults logfile="/var/log/sudo/log"` et `Defaults log_input, log_output`
- **Groupe :** Vérifier que `%sudo ALL=(ALL:ALL) ALL` est présent.

F. AppArmor

Pour Debian, AppArmor doit être actif.

- Vérifier : `sudo systemctl status apparmor`
- Activer si besoin : `sudo systemctl enable apparmor`

5. Script monitoring.sh et Cron

Le Script (monitoring.sh)

Le script doit être en Bash, exécutable, et afficher les informations sur **tous les terminaux** (utiliser la commande `wall`).

Informations à afficher (précision technique) :

1. **Architecture & Noyau :** `uname -a` (Affiche Linux, hostname, version kernel, date compile, arch).
2. **CPU Physique :** Nombre de processeurs physiques (distincts des cœurs). Commande : `cat /proc/cpuinfo | grep "physical id" | sort -u | wc -l`.
3. **CPU Virtuel (vCPU) :** Nombre total de cœurs logiques. Commande : `nproc` ou `cat /proc/cpuinfo | grep processor | wc -l`.
4. **RAM :** Disponible et % utilisé. Lire `/proc/meminfo` ou utiliser `free -m`. Calcul : (Total - Disponible) / Total * 100.
5. **Disque :** Espace utilisé et % sur la racine `/`. Commande : `df -h /`.
6. **CPU Load :** Taux d'utilisation instantané. Peut nécessiter un calcul basé sur `top` ou `vmstat` sur une courte période, ou lire `/proc/stat`.
7. **Dernier Boot :** Commande : `who -b` ou `uptime -s`.
8. **LVM Actif :** Vérifier si des volumes logiques sont montés. Commande : `lsblk` ou `lvm display`. Afficher "yes" ou "no".
9. **Connexions TCP :** Nombre de connexions établies. Commande : `ss -tan | grep ESTAB | wc -l` ou `netstat`.
10. **Utilisateurs connectés :** Commande : `who | wc -l`.
11. **IP & MAC :** Adresse IPv4 et adresse MAC de l'interface active. Commande : `ip -o addr show` et `ip link show`.
12. **Commandes Sudo :** Nombre de lignes dans le log sudo. Commande : `wc -l /var/log/sudo/log` (attention si le fichier n'existe pas encore).

Automatisation avec Cron

Le script doit s'exécuter toutes les 10 minutes.

- Éditer la crontab root : `sudo crontab -e`
- Ajouter la ligne : `*/10 * * * * /path/to/monitoring.sh`
- **Note :** Le script doit être exécutable (`chmod +x monitoring.sh`).

6. Checklist Finale avant Soumission

- [ ] Hostname est bien `sperrin42`.
- [ ] Utilisateur `sperrin42` existe et est dans les groupes `sudo` et `user42`.
- [ ] SSH tourne sur le port **4242** uniquement.
- [ ] Root ne peut pas se connecter en SSH.
- [ ] UFW est actif et bloque tout sauf 4242.
- [ ] Politiques de mots de passe appliquées et testées.
- [ ] Sudo configuré (logs, tty, essais, message).
- [ ] AppArmor est actif.
- [ ] Script `monitoring.sh` fonctionne et s'exécute via Cron.
- [ ] Aucun environnement graphique installé.
- [ ] Signature SHA1 générée et mise dans `signature.txt`.
- [ ] README.md rédigé (comparaisons Debian/Rocky, AppArmor/SELinux, etc.).
- [ ] Tous les snapshots supprimés avant la soutenance.

Rappel : Lors de la soutenance, vous devrez expliquer chaque commande, chaque fichier de configuration et le fonctionnement binaire sous-jacent (ex: comment le noyau gère les interruptions pour le timer Cron, comment PAM authentifie). La compréhension prime sur le résultat.